

CASE STUDY 2: ZERO TRUST MICRO-SEGMENTATION & ENTRA ID IDENTITY HARDENING

Enterprise Technical Case Study & Identity Architecture Reference Manual

PRIMARY TECHNICAL DOMAIN

Identity Architecture (IAM), Zero Trust & Micro-Segmentation

CORE PROTOCOLS & TECHNOLOGIES

BGP-EVPN over VXLAN, Entra PIM, ZTNA, CAE, SAML/OAuth

ALIGNED CERTIFICATIONS

SC-500, SC-104, Identity & Access Admin, Network+

SECURITY & IDENTITY STACK

Entra ID, Risk-Based CA, Entra Private Access, Defender

I. EXECUTIVE SUMMARY & CONTEXT

This enterprise project overhauled an aging flat corporate network and unmanaged identity perimeter into an end-to-end Zero Trust ecosystem. The initiative replaced standing administrative privileges with Microsoft Entra ID Privileged Identity Management (PIM), eliminated legacy authentication vector exposure, established Continuous Access Evaluation (CAE), replaced legacy inbound SSL VPNs with Entra Private Access (ZTNA), and engineered a Spine-Leaf BGP-EVPN over VXLAN data center fabric to micro-segment AI GPU model training clusters from corporate broadcast domains.

II. STAKEHOLDER DISCOVERY & INTERVIEW MATRIX

Prior to technical design, structured discovery sessions were conducted across executive and operational security leads to quantify risk vectors, identity sprawl, and performance requirements.

Stakeholder Role	Key Concerns & Questions	Uncovered Pain Points	Design Resolution
CISO & Threat Intel Lead	- Can an attacker move laterally to AI training nodes? - Are admin tokens prone to replay attacks?	- Flat L2 subnet enabled unrestricted lateral movement. - Lack of Continuous Access Evaluation (CAE).	Built a Spine-Leaf BGP-EVPN over VXLAN overlay with isolated VRFs and enforced CAE.
Identity & IAM Manager	- How many standing Global Admin accounts exist? - Are legacy auth protocols accepting traffic?	18 permanent Global Admins without JIT flows. - Legacy auth (IMAP) generated 70% of spray noise.	Enforced Entra ID PIM (4-hr JIT max) and disabled legacy authentication tenant-wide.
Head of AI & Data Science	- Will segmentation slow GPU synchronization? - How do remote teams access GPU nodes securely?	- Inbound SSL VPNs throttled dataset uploads. - Firewall DPI added latency to intra-cluster synchronization.	Deployed Entra Private Access (ZTNA) with line-rate L2/L3 VXLAN hardware offloading.
Helpdesk & User Support Lead	- Will MFA prompts cause user fatigue? - How do we govern third-party OAuth apps?	- Unhappy endusers about having to log in with MFA too many times a day, not just in each location or device. - Users routinely consented to risky third-party OAuth apps.	Enforced Risk-Based Conditional Access and admin-only OAuth registration workflows.

III. FORMAL SCOPE BOUNDARY STATEMENT

IN-SCOPE Deliverables • Identity & Access Hardening: Tenant-wide Entra ID PIM (JIT elevation, multi-party approvals), elimination of legacy auth, and Token Protection / CAE enforcement. • Zero Trust Network Access: Replacement of inbound SSL VPNs with Entra Private Access connectors enforcing per-app continuous authentication. • Network Micro-Segmentation: Spine-Leaf BGP-EVPN over VXLAN network fabric establishing dedicated VRFs for GPU clusters and corporate users. • Access Governance: Automated quarterly Entra ID Access Reviews and restricted admin-only app registration workflows.	OUT-OF-SCOPE Boundaries • Modernization or code rewrite of internal proprietary AI training algorithms and data pipelines. • Physical replacement of core datacenter UPS or power distribution infrastructure. • Identity migration of external customer-facing consumer directories (B2C isolated). • Local desktop endpoint hardware provisioning and physical workstation replacement.
--	--

IV. PRE-DESIGN BASELINE AUDIT ASSESSMENT

18 Admins STANDING GLOBAL ADMINS (0% JIT)	14,200 / day LEGACY AUTH PASSWORD SPRAY TRAFFIC	1,200 Endpoints FLAT L2 BROADCAST DOMAIN SCALE
---	---	--

V. CHRONOLOGICAL STEP-BY-STEP EXECUTION SEQUENCE

PHASE 1	Pre-Design Identity & Network Audit: Evaluated standing privileges, legacy protocol usage, and mapped flat Layer-2 data center traffic flows.
PHASE 2	BGP-EVPN / VXLAN Fabric Deployment: Constructed a Spine-Leaf data center overlay architecture providing hardware-offloaded line-rate routing.
PHASE 3	Micro-Segmentation & VRF Isolation: Established isolated Virtual Routing and Forwarding (VRF) instances separating GPU training nodes from general corporate subnets.
PHASE 4	Entra ID PIM Implementation: Transitioned all 18 standing Global Admins to eligible JIT roles requiring approval, justification, and 4-hour max windows.
PHASE 5	Risk-Based CA & CAE Enforcement: Deployed adaptive Conditional Access policies with Continuous Access Evaluation (CAE) and blocked all legacy auth protocols.
PHASE 6	Entra Private Access (ZTNA) Cutover: Deployed lightweight ZTNA connectors, decommissioning legacy inbound SSL VPN gateways for remote access.
PHASE 7	Non-Business Hours Migration: Executed identity policy cutovers and network overlay routing shifts during scheduled non-business maintenance windows.
PHASE 8	Validation & Penetration Testing: Conducted simulated lateral movement and token-hijacking attacks to confirm 100% policy enforcement and isolation.

■ VI. KEY METRICS & TECHNICAL IMPACT SUMMARY

Metric Category	Pre-Implementation Baseline	Post-Implementation Result
Standing Admin Accounts	18 Permanent Global Admins (0% JIT)	0 Permanent Admins (100% JIT elevation via Entra PIM)
Legacy Auth Traffic	14,200 password spray requests / day	0 Legacy Requests (100% blocked tenant-wide)
Lateral Movement Threat	Flat Layer-2 subnet across 1,200 nodes	Hardware Micro-Segmented via VXLAN VRFs
Remote Access Security	Inbound SSL VPN (Perimeter trust)	Entra Private Access (ZTNA) per-app continuous trust

■ VII. TECHNICAL ACCOMPLISHMENT SUMMARY

- **Identity Perimeter Hardening:** Eliminated standing administrative access by enforcing Entra ID Privileged Identity Management (PIM) with JIT elevation, multi-party approvals, and disabled all legacy authentication protocols tenant-wide (SC-500 / SC-104 compliant).
- **Zero Trust Network Access (ZTNA):** Replaced vulnerable inbound SSL VPN infrastructure with Entra Private Access connectors, enforcing continuous risk-based authentication and token protection against session hijacking.
- **Data Center Micro-Segmentation:** Designed and deployed a Spine-Leaf BGP-EVPN over VXLAN network fabric, isolating high-value AI GPU model training clusters into dedicated VRFs with hardware-accelerated line-rate security filtering.

■ VIII. STAKEHOLDER SENTIMENT, FINANCIAL MODEL & PROJECT OUTCOME

Financial Transparency, Operational Success & Strategic Client Expansion

Similar to prior modernization initiatives, stakeholders initially voiced concerns regarding the capital required for the new workstations and potential productivity friction caused by aggressive identity lockdown and network micro-segmentation.

We addressed these concerns by introducing a predictable, OpEx-aligned model structure with transparent cost boundaries:

- **Implementation Team Fees:** Fixed-fee professional services for IAM policy design, BGP-EVPN fabric staging, and cutover execution.
- **Maintenance & Monitoring Fees:** Predictable operational management for ongoing identity governance and telemetry monitoring.
- **Azure Cost Management & Entra Utility Tracking:** Real-time budget monitoring through the Azure Cost Management utility to track licensing and usage without surprise billing.

Upon reviewing the clear cost predictability and non-disruptive deployment strategy, stakeholders executed the agreement. The outcome yielded exceptional results across all technical, operational, and business expansion benchmarks:

- **Zero Performance Bottlenecks:** Line-rate VXLAN hardware offloading preserved high-speed intra-cluster synchronization for GPU model training without firewall latency.
- **Seamless Access & Reduced MFA Friction:** Unhappy endusers who previously voiced frustration over having to log in with MFA too many times a day across multiple locations and devices were transitioned to Risk-Based Conditional Access and Token Protection, eliminating redundant prompts.
- **Executive Confidence:** Executive leadership reported that even though there was a significant increase in capital for the new workstations, the security and high availability (HA) of their network—along with increased speeds and almost zero bottlenecks—was impressive.
- **Client Project Recommendations:** Based on the complete success of this engagement, our team was recommended by the stakeholders for two new enterprise projects:
 - **Attorney Firm:** A legal practice operating on a severely outdated network with intolerable security leaks exposing confidential client records.
 - **Food Manufacturing Company:** A manufacturing facility with an unsegmented, severely outdated network exposing critical operational technology (OT) assets.